

Risk Register

Project: Pocket Portfolio: Sovereign Financial AI
Programme: 6-month R&D | **Budget:** £150k
Architecture reference: `app/lib/ai/contextBuilder.ts` (`buildPortfolioContext`), `app/api/ai/chat/route.ts` (`stateless inference`), `app/components/ai/AskAIModel.tsx` (`client parse + attachedContent`), `app/components/CSVImporter.tsx` (local CSV import).

Risk Description	Category	Probability (1–5)	Impact (1–5)	Mitigation Strategy	Owner
Browser memory / main-thread stalls: In-dashboard CSV import reads full file text and runs broker parsers in the browser (<code>CSVImporter</code> ; <code>file.text()</code> / importer pipeline). Very large exports (approaching the 10MB soft gate) or pathological row counts can spike heap use or block the UI thread, degrading UX or failing import before any sanitisation boundary is reached.	Technical	3	4	Enforce/communicate clear file-size guidance; add chunked parsing or Web Worker offload for heavy paths; keep streaming or row-budget caps in sprint backlog; benchmark peak memory on representative 10k+ row fixtures during WP3.	Abba Lawal (PI)
Aggregate context still sensitive: <code>buildPortfolioContext</code> intentionally emits no raw ledger rows , but the output string includes ticker-level holdings, values, and trade counts (<code>TOP_HOLDINGS_COUNT</code> , portfolio totals). A regulator or adversary could treat this as client-confidential market exposure , distinct from “zero PII.” Mis-stating “anonymous” in external comms would create reputational / compliance exposure.	Regulatory	2	4	Use precise language (PII-free aggregate , not “anonymous”); document residual sensitivity in technical annex; optional further redaction (sector buckets, rounding) as a config flag after benchmarking signal loss.	Abba Lawal (PI)
Paid attachment path crosses row-level boundary: For paid tiers, <code>AskAIModel</code> may POST <code>attachedContent</code> (CSV normalised via <code>Papa.parse</code> , truncated client-side 50k chars / server 60k) into <code>/api/ai/chat</code> , where it is concatenated into the model prompt. This is not the same boundary as <code>buildPortfolioContext</code> alone— row-level text may reach the Frontier provider under their API terms.	Regulatory	3	5	Treat attachments as opt-in, tier-gated ; enforce caps; log metadata only (existing <code>toolUsage</code> / quota patterns); run benchmarked “leakage” tests on synthetic CSVs; review provider DP terms; avoid marketing language that implies <i>all</i> paths are aggregate-only.	Abba Lawal (PI)

Risk Description	Category	Probability (1–5)	Impact (1–5)	Mitigation Strategy	Owner
Frontier LLM provider dependency: <code>/api/ai/chat</code> calls Gemini (HTTP) with OpenAI fallback ; <code>maxDuration = 30</code> caps request time. Key misconfiguration, quota exhaustion, model deprecation, or regional outage can break inference regardless of local sanitisation quality.	Technical	3	4	Maintain dual-provider keys where budget allows; health-check keys in CI; graceful 503/502 UX; monitor error rates in existing analytics hooks; keep prompts within latency budget (aggregate context + optional attachment truncation).	Abba Lawal (PI)
Prompt-injection / instruction override: The route concatenates user message , context , optional attachedContent , and live quote snippets into one system/user prompt stream. A crafted CSV or message could attempt to steer the model off-domain or exfiltrate instructions—classic LLM abuse surface.	Technical	2	4	Harden system prompt (finance-only decline); strip or neutralise obvious control tokens in attachments where feasible; output-side checks in product (no secrets in client); periodic red-team prompts on synthetic data during WP3.	Abba Lawal (PI)
Single engineering lead / delivery concentration: The PI is sole accountable architect for WPs spanning browser ETL, API boundary, and LLM integration— key-person risk for sprint velocity, incident response, and Mo reporting.	Managerial	3	4	Ruthless scope control (2-week sprints, MoM actions); document runbooks in Notion ; use GitHub branch protection + CI as force-multiplier; schedule external code review or penetration test of the stateless boundary as a discrete WP3 deliverable (days, not FTEs).	Abba Lawal (PI)
Regulatory framing risk (DORA / FCA): The architecture supports data-minimisation and stateless server-side handling of prompts, but does not by itself constitute legal compliance. Misinterpretation in sales or grant reporting could over-claim “DORA-safe” or “FCA-compliant” without legal sign-off.	Commercial	2	5	Separate engineering claims from legal conclusions ; budget a short third-party regulatory memo (WP4) against stated controls; align website/grant language with audited technical mechanisms (<code>docs/IP-TECHNICAL-MECHANISMS.md</code> alignment).	Abba Lawal (PI) / Third-Party Auditor
Quota / monetisation misalignment: Free-tier monthly question limits and paid-tier behaviour are enforced in <code>/api/ai/chat</code> and <code>aiUsage</code> . Misconfiguration of Firestore tier docs or quota logic could block legitimate R&D demos or skew benchmark runs.	Managerial	2	3	Version-control tier rules ; add smoke tests for 401/403/429 paths; separate staging keys for experiments; document Mo-facing usage metrics from existing logs—not ad-hoc spreadsheets.	Abba Lawal (PI)

Probability / impact: 1 = Low, 5 = High. Mitigations are sized for a lean £150k programme (Agile sprints, benchmarking, targeted external review—not team scale-up).